TOPICOS · BILAGA TILL PERSONUPPGIFTSBITRÄDESAVTAL

Säkerhetsbilaga: tekniska och organisatoriska åtgärder

Rättslig grund	Dataskyddsförordningen (GDPR) artikel 28.3 c och artikel 32
Version	0.9, utkast
Datum	2026-11-09
Biträde	Råggywood AB, organisationsnummer 556972-3884, Sverige, som tillhandahåller tjänsten Topicos. Nedan "Råggywood".
Tjänst	Topicos: appar för iOS och Android samt webbapp på app.topicos.app
Kontakt	kontakt@topicos.app

1. Tjänsten i korthet

Topicos är en kommunikationstjänst för organisationer: chatt strukturerad i grupper och ämnen, röstsamtal, uppgifter, kalender, dokument och tidrapportering. Organisationen äger sitt innehåll. Varje organisation kan dessutom slå på end-to-end-kryptering (kallad Organisationsnyckeln), varvid innehållet krypteras på medlemmarnas enheter med nycklar som bara organisationen har. Råggywood AB kan då varken läsa, återställa eller lämna ut innehållet.

Den här bilagan beskriver de tekniska och organisatoriska åtgärder som skyddar personuppgifterna, med den detaljnivå en informationssäkerhetsgranskning behöver. En kortare, allmän beskrivning finns på topicos.app/sakerhet.

2. Arkitektur och lagringsplatser

Apparna talar direkt med Googles molnplattform (Firebase) och med Råggywoods serverkod som körs där. Filer lagras hos Cloudflare. Samtal förmedlas av LiveKit. Notiser levereras av Apple och Google. Betalning sköts av Stripe.

KOMPONENT	UNDERBITRÄDE OCH TJÄNST	INNEHÅLL	PLATS
Databas	Google Cloud Firestore	Meddelanden, dokument, uppgifter, kalender, tidrapporter, medlemskap, notiser, samtalshistorik	EU, multiregion eur3 (Belgien och Nederländerna, replikerat mellan regionerna)
Serverkod	Google Cloud Functions (2:a generationen), Node.js 22	Behandling vid skrivning, notiser, betalning, gallring. 50 funktioner	EU, europe-west1 (Belgien)
Filer och bilagor	Cloudflare R2	Bilder, video, ljud, dokument, uppgiftsbilagor	EU-jurisdiktion (Cloudflares jurisdiktionsbegränsning, inte bara platsledtråd)

KOMPONENT	UNDERBITRÄDE OCH TJÄNST	INNEHÅLL	PLATS
Övriga filer	Google Cloud Storage	Profilbilder och bilder till länkförhandsvisningar	EU, europe-west1
Inloggning	Google Firebase Authentication	Telefonnummer, inloggningssession, SMS-utskick	USA. Google uppger att tjänsten körs enbart i amerikanska datacenter
Notiser	Google Firebase Cloud Messaging, Apple Push Notification service	Push-token; notisinnehåll krypterat till enheten	Globalt
Samtal	LiveKit Cloud	Ljud i realtid, lagras aldrig	Närmaste mediaserver väljs per samtal; projektet är inte låst till en region. För samtal från Sverige har servern legat i Tyskland (EU)
Kraschrapporter	Google Firebase Crashlytics	Felinformation, enhetsmodell, operativsystem, konto-id	Globalt
Skydd mot missbruk	Google Firebase App Check	Enhets- och webbläsarsignaler	Globalt
Betalning	Stripe	Faktureringsuppgifter, abonnemangsstatus	EU/USA
Webbappen	Google Firebase Hosting	Enbart appens programfiler. Inga personuppgifter lagras	Globalt CDN
Appdistribution	Apple App Store, Google Play, Expo (EAS Update)	Appversioner och JavaScript-uppdateringar. Inga personuppgifter	Globalt

Hemligheter (API-nycklar, signeringsnycklar, nycklar till underbiträden) ligger i Google Secret Manager och finns aldrig i källkoden eller i konfigurationsfiler.

3. Kryptering

3.1 Under överföring

All trafik mellan appar, webbapp, serverkod och underbiträden går över TLS. Signerade fillänkar och API-anrop använder HTTPS.

3.2 I vila

Google Cloud (Firestore, Cloud Storage, Secret Manager) och Cloudflare R2 krypterar all lagrad data i vila med underbiträdets egna nycklar (AES-256). Det skyddar mot fysisk åtkomst till lagringsmedia men inte mot underbiträdet självt; det senare hanteras av end-to-end-krypteringen i 3.5.

3.3 Notisinnehåll

Push-notiser lämnar EU via Apples och Googles push-tjänster. Innehållet (avsändare, text, rubrik) krypteras därför på servern med AES-256-GCM med en nyckel som bara mottagarens enhet har. Nyckeln skapas på enheten och lagras i iOS Keychain respektive Android Keystore. På iOS avkodas notisen i ett notistillägg (Notification Service Extension) innan den visas; på Android i appen. Apple och Google ser bara push-token och ett krypterat paket. Äldre appversioner som saknar stödet får notiser via Expo i klartext, se avsnitt 12.

3.4 Bilagor och signerade länkar

Bilagor lagras under slumpade objektnamn utan filnamnet, och lagringen är inte publikt nåbar. Läsning sker via signerade länkar som serverkoden utfärdar efter att ha kontrollerat att användaren är medlem i den chatt, grupp eller organisation bilagan hör till. Länkarna gäller i 60 minuter och kan inte förlängas av klienten.

3.5 End-to-end-kryptering (Organisationsnyckeln)

Organisationens superadministratör kan slå på end-to-end-kryptering. Från den stunden gäller följande.

Nyckelmodell. Varje enhet skapar ett X25519-nyckelpar per användarkonto; den privata nyckeln lagras i enhetens skyddade nyckellager (iOS Keychain, Android Keystore, webbläsarens lagring på webben) och lämnar aldrig enheten. Organisationens innehållsnyckel (256 bitar) finns bara förseglad till varje godkänd enhets publika nyckel (X25519 + HKDF-SHA256 + AES-256-GCM). Innehåll krypteras med AES-256-GCM med bunden tilläggsdata som knyter chiffret till dokument och fält, så att ett chiffer inte kan flyttas till en annan plats. Bilagor får en egen slumpad nyckel per fil som ligger inne i meddelandets chiffer, krypteras i block före uppladdning, och lagras som binära objekt utan filnamn eller filtyp.

Enhetsgodkännande. En ny enhet kan inte läsa något förrän en administratör, eller en av användarens redan godkända enheter, har jämfört enhetens verifieringskod och godkänt den. Godkännandet är det som ger enheten nycklarna; servern kan inte utföra det.

Rotation. Innehållsnyckeln byts (ny nyckelepok) när en enhet återkallas, när en medlem tas bort ur organisationen, när återställningsfrasen byts och när krypteringen slås på igen. Enheter som lämnat får inte den nya epoken och kan därför inte öppna innehåll som skapas efter bytet. Lämnar en medlem själv får administratörerna en notis om att byta nyckel.

Återställningsfras. När krypteringen slås på visas en fras med 24 ord (BIP39) en enda gång. Ur den härleds ett nyckelpar som varje nyckelepok också förseglas till. Frasen är organisationens huvudnyckel och behövs bara om ingen godkänd enhet finns kvar. Råggywood har inte frasen, ber aldrig om den och kan inte återställa innehåll utan den. Frasen kan bytas från en godkänd superadministratörsenhet, men bara med den gamla frasen i hand.

Omfång. Krypteras: meddelanden (text, svar, omröstningar, platsdelning, avsändarnamn), bilagor, dokument och textdokument inklusive bilder, uppgifter med anteckningar och bilagor, kalenderhändelser, notiser, namn på grupper, ämnen och mappar, samt samtal (ljud och datakanal via LiveKits ramkryptering med en samtalsnyckel härledd ur epoknyckeln). I klartext, medvetet:

organisationens namn, medlemmarnas profilnamn och telefonnummer, tidrapporten, innehåll från före aktiveringen, och metadata (medlemskap, tidsstämplar, vem som skrivit till vem).

Vad Råggywood ser. Krypterat innehåll och metadata. En begäran från myndighet kan bara besvaras med det: chiffer vi inte kan öppna, samt uppgifter om medlemskap och tidpunkter.

Begränsningar. Krypteringen skyddar inte mot en upplåst, godkänd enhet; inte mot metadataanalys; och inte mot en manipulerad app, eftersom krypteringen utförs av appens kod (koden är inte öppen, ingen extern granskning är gjord). Sökning sker lokalt på enheten. Länkförhandsvisningar visas inte i krypterade organisationer. Krypterade samtal fungerar i mobilapparna men ännu inte i webbläsaren.

4. Åtkomstkontroll

4.1 I tjänsten

- **Autentisering** sker med telefonnummer och engångskod via SMS (Firebase Authentication). Sessionen är knuten till enheten.
- **Behörighetsregler i databasen** (Firestore Security Rules) avgör vid varje läsning och skrivning om användaren är medlem i den organisation, grupp, chatt eller privata konversation som posten tillhör. Reglerna körs hos Google och kan inte kringgås från klienten.
- **Roller**: superadministratör (en per organisation, kan delegera), administratör och medlem. Bara superadministratören kan slå på och av krypteringen, tidrapporteringen och byta återställningsfras. Attestering av tidrapporter kräver särskild behörighet.
- **Export av chatt**: superadministratören och administratörer kan exportera ett ämne som en zip-fil med meddelanden och valda bilagor, för arkivering eller utlämnande. Exporten görs på enheten, så att innehållet inte passerar Biträdet i läsbar form. Filen är okrypterad och hanteras av organisationen som andra handlingar.
- **Bilagor** nås enbart via signerade länkar utfärdade efter behörighetskontroll (3.4).
- **Serveranrop** kräver Firebase App Check: Play Integrity (Android), App Attest (iOS) och reCAPTCHA v3 (webb) intygar att anropet kommer från den riktiga Topicos-appen. Alla serverfunktioner avvisar anrop utan giltigt intyg.
- **Åtkomsten upphör direkt** när en medlem tas bort ur en grupp eller organisation; i krypterade organisationer roteras dessutom nyckeln.

4.2 Administrativ åtkomst till produktionsmiljön

- Produktionsmiljön (Google Cloud, Cloudflare, Stripe, LiveKit, Expo, Apple och Google Play) administreras av en person hos Råggywood AB, bolagets grundare. Ingen annan har åtkomst.
- Samtliga konton hos underbiträden och tjänsteleverantörer, inklusive GitHub där källkoden och webbplatsen ligger, skyddas av tvåfaktorsautentisering.
- Personal med administrativ åtkomst har teknisk möjlighet att läsa okrypterat innehåll via underbiträdenas administrationskonsoler. Sådan läsning sker bara vid felsökning på organisationens skriftliga begäran, och dokumenteras med tidpunkt, vem som läste och vilket innehåll. I organisationer med end-to-end-kryptering är innehållet oläsligt även för personal med full åtkomst.

- Underbiträdenas API-nycklar är begränsade till minsta nödvändiga behörighet. Nyckeln till fillagringen är till exempel bunden till en enda bucket i EU-jurisdiktionen.

5. Skydd mot missbruk och felaktig användning

- App Check stoppar anrop som inte kommer från den riktiga appen (4.1).
- Länkförhandsvisningar hämtas av serverkoden, inte av användarens enhet, med storleks- och tidsgräns, så att en länk i en chatt inte kan användas för att spåra mottagarna.
- Bilagor delas mellan meddelanden med referensräkning, så att radering i en chatt inte tar bort en fil som fortfarande visas i en annan, och omvänt att en fil raderas när ingen längre refererar den.
- Gratisplanen har tak för lagring och samtalsminuter som kontrolleras på servern.

6. Loggning och spårbarhet

- Serverkoden loggar till Google Cloud Logging. Loggarna innehåller identifierare (användar-, organisations- och meddelande-id) men inte innehåll, namn eller telefonnummer; loggning av sådana uppgifter togs bort i augusti 2026. Sedan 2026-09-15 lagras loggarna i en egen loggbucket i EU (europe-west1) med 30 dagars lagringstid; den globala standardbucketen tar inte längre emot nya loggar.
- Administrativa ändringar i molnprojektet (Admin Activity-loggar: ändrade behörigheter, konfiguration, deployer) loggas automatiskt av Google Cloud och sparas i 400 dagar.
- Data Access-loggar för Firestore (Admin Read och Data Read) är påslagna sedan 2026-09-15. Varje läsning av databasen, från administrationskonsol, skript eller app, loggas med tidpunkt, anropande identitet och vilket dokument eller vilken fråga det gällde. Loggposten innehåller anroparens inloggningstoken, som för appanvändare bär telefonnumret, men inte dokumentens innehåll. Skrivningar (Data Write) loggas avsiktligt inte, eftersom sådana poster skulle innehålla dokumentens innehåll och därmed bli en andra lagringsplats för meddelanden. Loggarna ligger i EU-bucketen ovan, gallras efter 30 dagar och läses bara vid felsökning eller incident.
- Ett larm i Cloud Monitoring (sedan 2026-09-15) utlöses när serverfunktionerna svarar med fler än fem serverfel (HTTP 5xx) under fem minuter, och skickar SMS och e-post till incidentansvarig både när larmet går och när felen upphört. Avvisade App Check-anrop larmar inte men syns i loggarna.
- Stripe för fullständig historik över betalningar och abonnemangsändringar.
- I krypterade organisationer finns en enhetslista per organisation med status, verifieringskod, när enheten begärdes, godkändes eller återkallades och när den senast var aktiv, synlig för administratörerna i appen.
- Tjänsten har ingen audit-logg för slutanvändare av typen "vem läste vad". Se avsnitt 12.

7. Säkerhetskopiering, redundans och kontinuitet

- Databasen är en multiregional Firestore-instans som replikeras synkront mellan två EU-regioner; bortfall av en region ger inget dataavbrott.
- Säkerhetskopiering av databasen: point-in-time recovery (återställning till valfri minut de senaste 7 dagarna) och daglig schemalagd säkerhetskopia som sparas i 30 dagar. Båda är påslagna sedan

2026-09-14. Kopiorna lagras i samma region som databasen och återställs till en ny databas, varefter tjänsten pekas om.

- Fillagringen (Cloudflare R2) lagrar objekt redundant inom EU-jurisdiktionen. Separat versionering eller backup av filer finns inte.
- Serverkoden är tillståndslös och återskapas från versionshanterad källkod på minuter.
- Mål för återställning: tjänsten ska vara i drift igen inom 24 timmar efter ett haveri (RTO), och högst en timmes data får gå förlorad (RPO).
- I organisationer med end-to-end-kryptering är organisationens återställningsfras och godkända enheter en förutsättning för att en återställd databas ska vara läsbar. Råggywood kan återställa chiffret men inte nycklarna.

8. Radering och gallring

- Meddelanden som raderas tas bort ur databasen direkt. Bilagan raderas ur fillagringen när inget meddelande längre refererar den (serverfunktion vid radering, med referenskontroll).
- Grupper och ämnen som markerats för radering raderas automatiskt med allt innehåll när fristen gått ut (dagligt jobb).
- Lästa notiser raderas efter 90 dagar. Obesvarade inbjudningar, som innehåller den inbjudnas telefonnummer, raderas efter 30 dagar.
- Föräldralösa bilder i textdokument gallras av ett schemalagt jobb.
- Organisationer med uppsagt betalabonnemang: superadministratören varnas 60 och 80 dagar efter uppsägningen; efter 90 dagar raderas organisationens filer och organisationen avaktiveras.
- Kontoradering (i appen) tar bort profil, telefonnummer, profilbild, inloggning, push-token, enhetsnycklar och medlemskap. Innehåll användaren skapat i organisationer ligger kvar hos organisationen.
- I krypterade organisationer innebär förstörda nycklar att innehållet är oläsligt även om chiffret finns kvar i en säkerhetskopia (kryptografisk radering).
- Gratisplanen döljer meddelanden äldre än 90 dagar men raderar dem inte.

9. Utveckling, förändringshantering och leverans

- All källkod är versionshanterad (git, GitHub). Varje ändring är spårbar till en commit.
- Behörighetsreglerna i databasen är kod och versionshanteras tillsammans med appen.
- Appar släpps via App Store och Google Play, som granskar varje version. JavaScript-delen kan uppdateras mellan butiksversioner via Expo EAS Update; sådana uppdateringar är knutna till en viss binärversion och kan inte ändra appens native-kod.
- Uppdateringar via Expo är inte kodsignerade med Råggywoods egen nyckel (det kräver Expos företagsplan). Skyddet är Expo-kontots åtkomstkontroll. Se avsnitt 12.
- Beroenden uppdateras löpande. Automatisk sårbarhetsskanning av beroenden finns inte; se avsnitt 12.
- Testning sker mot produktionsmiljön med särskilda testkonton och testorganisationer. Testdata blandas inte med kundorganisationers data, men någon separat testmiljö finns inte.

10. Incidenthantering

Personuppgiftsincidenter hanteras enligt den separata incidentrutinen, som delas vid avtalstecknande: begränsa, bedöma, underrätta den personuppgiftsansvarige utan onödigt dröjsmål, dokumentera och följa upp. Rutinen anger vad underrättelsen innehåller och hur organisationen nås.

11. Organisatoriska åtgärder

- Råggywood AB är ett litet bolag; utveckling och drift sköts i dag av en person, grundaren. Bolaget kan vid behov, till exempel vid ett större kundåtagande, utöka driftorganisationen till minst tre personer. Alla med åtkomst omfattas av sekretess.
- Principen om minsta behörighet tillämpas på konton hos underbiträden och API-nycklar.
- Kontinuitet vid bortfall av nyckelperson: en namngiven ställföreträdare med deponerade åtkomstuppgifter (till exempel nödåtkomst i lösenordshanteraren) och en skriftlig driftsbeskrivning, så att tjänsten kan hållas i drift och avvecklas ordnat utan grundaren.
- Dataskyddsombud är inte utsett. Kravet i artikel 37 gäller myndigheter och verksamheter vars kärnverksamhet är storskalig övervakning eller storskalig behandling av känsliga uppgifter; Topicos når inte dit vid nuvarande omfattning. Frågan omprövas när kundbasen växer.
- Underbiträden används enligt den separata underbiträdesförteckningen. Organisationen meddelas innan ett nytt underbiträde tas i bruk.

12. Kända begränsningar

Följande är avsiktligt redovisat så att den personuppgiftsansvarige kan väga det i sin riskbedömning.

- Ingen extern säkerhetsgranskning eller penetrationstest är gjord, och ingen certifiering (ISO 27001 eller motsvarande) finns.
- Telefonnumret för inloggning behandlas i USA (Firebase Authentication). End-to-end-krypteringen täcker inte det.
- Samtalens ljud passerar LiveKits servrar i klartext i organisationer utan end-to-end-kryptering. Projektet är inte låst till en EU-region; LiveKit väljer närmaste server, vilket för samtal från Sverige har varit Tyskland. Deltagarnas visningsnamn ingår i anslutningstoken till LiveKit; en ändring till enbart id är förberedd.
- Äldre appversioner får notiser via Expo med förhandsvisning i klartext (i krypterade organisationer bara organisationens och avsändarens namn). Andelen minskar i takt med att användarna uppdaterar.
- Metadata (medlemskap, tidsstämplar, vem som skrivit till vem) är i klartext även med end-to-end-kryptering.
- JavaScript-uppdateringar är inte kodsignerade med egen nyckel.
- Ingen audit-logg för slutanvändare, ingen inloggning med organisationens identitetslösning (SSO), ingen separat testmiljö, ingen automatisk sårbarhetsskanning av beroenden.
- Krypteringens kod är inte öppen källkod.

- Tjänsten står på underbiträden med amerikanskt moderbolag (Google, Cloudflare, LiveKit), som omfattas av amerikansk extraterritoriell lag oavsett var servrarna står. Innehållet är skyddat genom end-to-end-krypteringen, men identitetsuppgifter och metadata är det inte. Råggywood kan flytta samtalsservern och fillagringen till EU-ägd infrastruktur inom veckor, och databasen och inloggningen inom en längre projektperiod. En sådan flytt är möjlig som avtalad utveckling om en organisation har det som krav, och diskuteras gärna innan avtal tecknas.

13. Ändringshistorik

VERSION	DATUM	ÄNDRING
0.1	2026-09-10	Första utkast efter införandet av end-to-end-kryptering och flytten av all behandling till EU.
0.2	2026-09-14	Partsbeteckningen "Biträdet" införd; externa leverantörer kallas genomgående underbiträden. Avsnitt 12: möjlig flytt till EU-ägd infrastruktur som avtalad utveckling.
0.3	2026-09-15	Avsnitt 7: point-in-time recovery och daglig säkerhetskopia påslagna 2026-09-14; markören borttagen.
0.4	2026-09-15	Avsnitt 6: loggbucket i EU (europe-west1, 30 dagar) och Data Access-loggar (Admin Read, Data Read) för Firestore påslagna 2026-09-15; markören borttagen.
0.5	2026-09-15	Avsnitt 6: larm på serverfel (5xx) i Cloud Monitoring med SMS och e-post, påslaget 2026-09-15; markören borttagen.
0.6	2026-09-15	RTO/RPO och ställföreträdare beslutade; markörer borttagna.
0.7	2026-09-21	Avsnitt 11: incidentrutinen publiceras inte längre utan delas vid avtalstecknande; länken borttagen.
0.8	2026-10-08	Avsnitt 4.1: export av chatt till zip-fil, gjord på enheten.
0.9	2026-11-09	Avsnitt 3.5: rotationen beskriven som att enheter som lämnat inte kan öppna innehåll som skapas efter bytet.